

CONTAINER: Bounding Credential-Compromise Impact in IEEE 2030.5 DER Systems

Huan Bui*

University of North Carolina at Charlotte, Charlotte, NC, USA

Abstract

IEEE 2030.5 authenticates distributed energy resources with device certificates that do not expire and cannot be revoked; the standard’s sanctioned substitute is a local allow/deny list. The accessible standards material does not specify whether denying an identity terminates an established session or retracts an already-issued control. Under the permissive reading it leaves open, denial reaches neither, and a compromise survives the response that is supposed to end it. CONTAINER separates bootstrap identity from short-lived attested operational authority and enforces expiry at the credential, session and command-effect layers, deployable through a gateway proxy. We quantify what each layer is worth on two public feeders over twenty paired seeds. Against a long-lived credential, adding session termination to identity denial removes 50.0% of integrated feeder harm (CI [46.5, 54.1]) and adding command cancellation 69.5% (CI [65.8, 77.5]). The two enforcement mechanisms are separately necessary and fail alone for different reasons: session enforcement leaves a command overhang of one control duration, while command cleanup is defeated outright by an adversary that re-issues over its still-open session. On the authorization side, a reactive bound admitting zero absorption fails to contain where an absorption floor of identical width contains, at negligible cost to volt-var service. That effect is conditional on a measurable quantity: it scales with the reactive absorption

*Corresponding author.

Email address: `hbui11@charlotte.edu` (Huan Bui)

the feeder actually draws rather than with PV penetration, and at a compliant operating point it is an order of magnitude smaller than at an overstressed one. Bounded lifetime truncates exposure rather than attenuating it, at a measured cost in regulator operations.

Keywords: Critical infrastructure protection, distributed energy resources, IEEE 2030.5, remote attestation, authorization, cyber-physical security

1. Introduction

Distributed energy resources now participate in grid operations at a scale that makes their control interface a systemic concern. IEEE 2030.5 (Smart Energy Profile 2.0), profiled for distribution use by the Common Smart Inverter Profile (CSIP), is the application protocol through which utilities and aggregators dispatch inverter-based resources. An adversary who obtains a credentialed identity in this ecosystem does not merely read data; it commands real and reactive power on physical hardware connected to the grid.

Two properties of the trust model make this harder than a conventional credential-theft problem. The device’s bootstrap identity and its operational authorization are the same certificate, so there is no separate short-lived credential to lose. And that certificate does not expire and cannot be revoked: the analysis of record for these standards states that the PKI is distinguished by “the use of non-expiring certificates and the explicit prohibition of CRL and OCSP”, and that “if the device’s private key is compromised, the device certificate cannot be revoked” [1]. What the standard offers instead is a local allow or deny list.

The obvious objection is that a denylist is enough — the operator refuses the compromised identity and the incident is over. **That holds only if denial reaches more layers than the standards material specifies, and nothing we could find says it does.** Nothing in the accessible sources states that adding an identity to a deny list terminates that identity’s established mutual-TLS session, or cancels a `DERControl` it has already installed. A denial that

refuses new sessions and does nothing else leaves an adversary who is already connected in full possession of both. Containment fails not because authority cannot be withdrawn, but because withdrawing it at one layer leaves two others running — and Section 8 measures what closing each of those two is worth.

That observation organises the paper. Bounding a DER compromise requires controlling two independent quantities: the *set of physical actions* an authorization admits, and the *duration* for which authority remains effective at every layer that can carry it — the credential, the open session, and the issued command.

CONTAINER separates bootstrap identity from short-lived, attested, scope-bound operational authority, and enforces expiry at all three layers. Because grid actuation persists in a way computation does not, expiry that stops at the credential is not containment: a credential lifetime with neither session nor command enforcement leaves an adversary’s open session and issued control untouched, and command cleanup without session enforcement is defeated because the adversary re-issues over the session that is still open.

Contributions

- *A DER credential and enforcement architecture* that separates bootstrap identity, operational credential and value-constrained authorization, and enforces expiry at the credential, session and command-effect layers, deployable through a gateway proxy that leaves downstream IEEE 2030.5 endpoints unmodified.
- *A measurement of what each containment layer is worth.* Against a long-lived credential, adding session termination to identity denial removes 50.0% of integrated feeder harm (CI [46.5, 54.1]) and adding command cancellation 69.5% (CI [65.8, 77.5]), paired by seed and Holm-corrected. The two enforcement mechanisms are separately necessary and fail alone for different reasons: session enforcement leaves a command overhang of one control duration, while command cleanup is defeated by an adversary that re-issues over its still-open session.

- *An authorization-shape result, with the condition under which it matters.*

At identical width, a reactive bound that admits zero absorption fails to contain where an absorption floor contains, at negligible cost to volt-var service. The magnitude of that effect scales with the reactive absorption the feeder is actually drawing rather than with PV penetration; it survives at an operating point where legitimate operation is compliant, but is an order of magnitude smaller there than at an overstressed one.

- *A corrected, released evaluation harness on two public feeders, with a pre-registration committed to version control before any treatment arm ran, every departure from it disclosed, and two defects in the predecessor harness identified and repaired.*

We claim no novelty for short-lived certificates or for expiry-based containment. The Web PKI ratified that trade in 2023 [2], and the Sandia analysis of these very standards recommends limited-life certificates and records that manufacturers are “not required to limit the life of a device certificate” [1] — which makes a short-lived operational credential permitted rather than new. What is new here is the mapping onto DER authorization: which layers expiry must reach before it contains anything, which control point an authorization must withhold, and the operating condition that decides whether either matters.

2. Background and Threat Model

2.1. Authorization in IEEE 2030.5 / CSIP

IEEE 2030.5 uses mutual TLS with X.509 device certificates. A device’s identity is the certificate-derived LFDI/SFDI, and its authorization is scoped by a `FunctionSetAssignments` resource binding it to one or more `DERPrograms`. Physical control authority is carried by the `DERControlBase` modes: active-power capping (`opModMaxLimW`), signed fixed active power (`opModFixedW`), reactive power (`opModFixedVar`, `opModVoltVar`), volt-watt and frequency-watt curves, and the hard connect and energize controls [3]. The standard specifies

certificate-based authentication and function-set scoping; it does not mandate a single canonical access-control object, and no accessible source establishes that it can bound the *value* a control may take. That distinction is where our design sits, and Section 4 states it plainly rather than implying native expressiveness.

2.2. Six ways authority can be withdrawn, and what each reaches

The literature tends to treat “revocation” as one thing. It is six, and they terminate different layers, which is the whole reason a compromise can outlive the response to it:

1. *PKI revocation* — a CRL or OCSP status marks the certificate invalid.
2. *Local identity denial* — the server refuses the certificate-derived identity.
3. *Authorization removal* — `FunctionSetAssignments` or `DERProgram` membership changes.
4. *Session termination* — an established authenticated channel is closed or forced to revalidate.
5. *Command cancellation* — a scheduled or latched `DERControl` is withdrawn, superseded, or replaced by a safe default.
6. *Identity replacement* — the device is re-enrolled or re-keyed.

Only the first is unavailable by construction. The motivating claim of this paper is therefore not that IEEE 2030.5 offers no way to withdraw authority — it offers the second, and CSIP builds enrollment on it — but that **the end-to-end time from deciding to contain a compromise to the cessation of all effective physical authority is not bounded by any of them individually**. Denying an identity refuses future authorization. On its own it neither closes an open session nor retracts a control already issued, and Section 8 measures how much of an attack survives it.

2.3. What the accessible standards material establishes

Certificate management differs across editions: IEEE 2030.5-2018 [4], IEEE 2030.5-2023 [5] (which supersedes it, published December 2024), and the

profile in force [6]. **We were unable to obtain IEEE 2030.5-2023.** It is paywalled at roughly US\$255 and is not in the IEEE GET programme. Every claim below is evidenced against the 2018 edition and the Sandia analysis of it [1], whose full text is freely available; Table 1 gives each claim its source and its exposure, and Section SM.1 of the supplement reproduces the supporting quotations verbatim.

Three points are settled by that material and matter to the design.

Certificates do not expire, and revocation is prohibited for IEEE 2030.5 certificates. The Sandia analysis states that the PKI is distinguished by “the use of non-expiring certificates and the explicit prohibition of CRL and OCSP”, that “once issued, a device certificate has an indefinite lifetime”, and that “if the device’s private key is compromised, the device certificate cannot be revoked” [1]. The prohibition is specific: OCSP “may only be used to verify non-IEEE 2030.5 certificates”. We state the qualification because an unqualified claim that the protocol forbids OCSP outright is wrong.

Local allow/deny listing is the sanctioned substitute, and is weaker than revocation. It is permitted, not required. The same analysis is explicit about its limits: “a blacklist is essentially a local CRL but without the process, rigor and verification behind its issuance”, and “it is possible for a stolen device certificate that was disallowed in one region to be used in a different region to gain access because it was only locally blacklisted”.

A short-lived operational credential is permitted, not prohibited. Manufacturers following the guidance “are not required to limit the life of a device certificate”. Limited-life certificates are in fact recommended, at a one-year renewal interval. CONTAINER’s contribution is therefore not the short lifetime, which is neither novel nor disallowed, but the enforcement of expiry at the session and command-effect layers, on which the accessible material is silent.

2.4. Three separated layers

We separate three layers the baseline conflates. *L1, bootstrap identity*: the hardware-rooted device certificate. *L2, operational credential*: what authorizes

Table 1: Standards claims the argument uses, the free source of record, and residual exposure. SAND = Sandia SAND2019-1490 [1], full text public; CSIP = Common Smart Inverter Profile v2.1 [6]. **No row has been checked against IEEE 2030.5-2023**, which could not be obtained.

ID	Claim	Free source	Residual risk
S1	Device certificate lifetime indefinite	SAND §4.1, §6.4, verbatim	2023 clause unread
S2	CRL prohibited for 2030.5 certificates	SAND §4.1, verbatim	2023 clause unread
S3	OCSF prohibited <i>for 2030.5 certificates</i> ; permitted for others	SAND §6.4, verbatim	2023 clause unread
S4	Local allow/deny listing permitted, not required, and unsynchronised	SAND §4.1, §4.1.2	low
S5	Short-lived operational credential permitted	SAND §6.4, verbatim	low
S6	LFDI/SFDI derives from certificate	SAND §3.1.1; CSIP §5.2.1.2	low; two sources
S7	FunctionSetAssignments scopes <i>functions</i> ; numeric value bounds not established	CSIP §5.2.3.1	design depends on it ; see §4
S8	Scheduled DER controls persist	CSIP §4.4.2, §6.1.8.2	high ; 2023 drops mandatory DER-Control modes

live sessions to an aggregator or DER management system. *L3, authorization scope*: the server-side binding from an identity to the function sets and values it may invoke. In baseline IEEE 2030.5, L1 and L2 are the same indefinitely valid certificate, with no attestation gate. That conflation, not any cryptographic weakness, is what makes a compromise persist.

2.5. Compromise classes and what bounds each

Retained authority differs by compromise class, and reporting one figure for all of them is the error the pilot made. Table 2 gives the classes, the mechanism that bounds each, and the resulting expectation. The deriva-

Table 2: Compromise classes, the mechanism that bounds each, and expected retained authority. T is the credential lifetime and p the per-renewal detection probability. Arrival is uniform within the epoch unless stated.

Compromise class	Bounding mechanism	Expected retention
Copied operational key	fresh key each epoch	$T/2$; <i>independent of p</i>
Persistent, attested	attestation-gated renewal	$T(1/p - 1/2)$
Persistent, unmeasured	none; scope only	unbounded
Stolen active session	session-age or per-command revalidation	$\min(T_{\text{age}}, T_{\text{reval}})$
Persistent command	duration cap, cancellation, safe restore	$\min(T_{\text{dur}}, T_{\text{cancel}})$
Stolen bootstrap key	hardware binding, enrollment policy	enrollment-controlled
Compromised gateway	gateway attestation, issuer policy	not bounded downstream
Compromised issuer	governance, HSM, audit	protection boundary

tions and their Monte-Carlo checks are in `pkimodel/retention.py` and `tests/test_retention.py`.

Two entries deserve emphasis because an earlier version of this paper got them wrong. For a *copied operational key* held by an adversary who is not resident on the device, attestation has nothing to detect: renewal mints a fresh key whether or not anything is found, so retention is bounded by the remaining epoch at $T/2$ in expectation, *independently of the detection probability*. For a *persistent* compromise re-checked at each renewal with probability p , the familiar T/p holds only when the compromise arrives immediately after an issuance; under uniform arrival within the epoch the expectation is $T(1/p - 1/2)$. At $T = 6$ h and $p = 0.2$, reporting T/p for a copied key claims 30 h of retention where the true expectation is 3 h.

2.6. Assets, adversary, and goals

Protected assets: DER control integrity, fleet authorization, operational and attestation keys, feeder stability and service continuity. *Adversary capabilities:*

steals an operational key, compromises firmware, steals an active session, compromises a gateway or aggregator, issues protocol-conformant commands within its authorization, and observes authorized telemetry. It does not break TLS or the underlying cryptography. *Exclusions*: breaking standard cryptography, physical destruction, and compromising both the root issuer and all audit controls, which we treat as the protection boundary rather than a defended case. *Security goals*: least authority, bounded new-session authority, bounded active-session authority, bounded command-effect duration, fresh-key containment, replay resistance, safe degradation, auditability. *Non-goals*: defending against malicious root issuance without added governance, detecting every hardware attack, replacing grid protection, and proving safety for every feeder. Attestation detects only what the evidence measures and the reference-value policy distinguishes; a stolen operational key on a device with intact firmware passes it, which is why fresh-key binding rather than attestation is what bounds that class.

3. Impact Accounting, and Why Reachability Alone Cannot Rank These Designs

This section fixes notation and says why we need it. As the introduction states, it is *not* a contribution: an extended attack graph [7, 8, 9] yields exactly the accounting below and so agrees with us rather than competing. We keep the notation only because the experiments in Section 8 move “how much”, “for how long”, and “under which grid conditions” differently, and one scalar cannot express that.

Substrate and the four quantities.. A static privilege graph $G = (V, E)$ has principals and resources as nodes and access relations as edges; $x \subseteq V$ is a set of compromised credentials, and a policy $\pi = (L, \text{Att}, A)$ gives a lifetime function L , an attestation-gated renewal predicate Att , and a scope map A . The device and grid state u_t and the feeder power-flow and protection model F appear nowhere in G , which is the point.

Cyber reach $\text{BR}_{\text{reach}} = \text{ReachSet}(x, \pi)$, a count, is the least fixed point of the π -enabled access relation from x : the endpoints the compromised authority can send an authenticated request to. *Commandable flexibility* BR_{flex} , in kW and kVar, is the aggregate over reachable DERs of the feasible set-point region $\mathcal{C}_d(t; u_t, A_\pi(d))$ given irradiance, state of charge, and inverter limits; a read-only scope yields the current set-point alone, hence zero. *Retained authority* separates three durations, in seconds,

$$\text{BR}_{\text{auth}} = (T_{\text{cred}}, T_{\text{sess}}, T_{\text{cmd}}), \quad (1)$$

where T_{cred} runs until the stolen credential is refused for a *new* session, T_{sess} until already-authenticated sessions can no longer issue commands, and T_{cmd} until queued or latched controls stop affecting the DER; the capacity-time exposure $\text{BR}_{\text{exp}} = \int \text{BR}_{\text{flex}}(t) \mathbf{1}[\text{authority effective}] dt$ carries kW·h or kVar·h. **We report the vector and not its maximum.** A maximum is the obvious summary and it is the wrong one here: the three components are bounded by three different mechanisms, and collapsing them hides which one failed. Section 8 measures arms whose maxima are identical and whose components — and physical consequences — are not. Expiry bounds T_{cred} alone. *Physical consequence* $\text{BR}_{\text{phys}} = \max_a J_V(F, u, a)$ is the worst outcome reachable within the adversary’s authority, where J_V is the voltage-violation area outside the ANSI C84.1 band weighted by magnitude. BR_{phys} carries two units and we label every table with which: *p.u.-node* evaluated at one operating point, and *p.u.-node-min* accumulated over a horizon. Secondary metrics are maximum per-unit deviation, violating-node count, protection-screen crossings, regulator tap operations, energy not served, unnecessary curtailment, and recovery time.

Three separations, true by construction.. Call a measurement *reachability-only* if it is a function M of $\text{ReachSet}(x)$ alone. Then, at fixed reachable set, varying the scope map changes BR_{flex} ; an attestation-gated ephemeral credential and a long-lived unrevoked one differ in BR_{auth} and BR_{exp} ; and the same authorized command is harmless at one operating state and crosses the IEEE 1547 over-voltage screen at another. **None of these can fail**, since M is single-valued

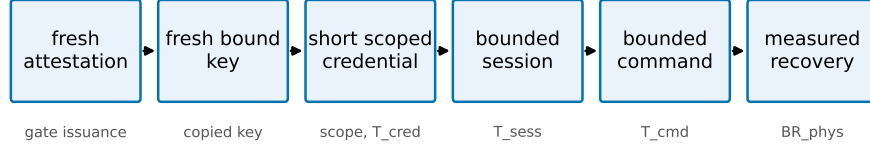


Figure 1: The CONTAINER containment chain. Each link bounds a dimension: attestation gates issuance, fresh-key binding contains a copied key, scope and short lifetime bound BR_{flex} and T_{cred} , session and command enforcement bound T_{sess} and T_{cmd} , and measured recovery bounds BR_{phys} .

in $ReachSet(x)$ and each construction varies a quantity that is by definition not an argument of M . They restate a definition. We keep them only because they say which quantities an evaluation must move, and each ships as a regression test in the released engine. **They are not evidence for the design; that is in Section 8, and only there.**

4. CONTAINER Design

CONTAINER separates the layers that IEEE 2030.5 conflates and enforces credential lifetime at the session and command layers, not only at issuance. The design is a containment chain: fresh attestation, a fresh hardware-bound key, a short scoped operational credential, a bounded session, and a bounded command effect, so that removing authority actually removes control. Each link targets a dimension of the model (Fig. 1).

4.1. Components and trust layering

The device keeps a long-lived, hardware-rooted bootstrap identity [10] used only for enrollment and attestation, never accepted directly for DER control. An *attester* produces fresh evidence bound to a freshly generated operational public key; a *verifier* checks evidence against endorsement and reference values and returns an explicit result; a *credential issuer* signs a short-lived operational certificate embedding role, site, scope, and expiry only for a valid attestation

result; an *authorization service* maps the operational identity to least-privilege function-set assignments; the *2030.5 server or proxy* authenticates the operational certificate, enforces a maximum session age, and rechecks authorization per command or at a bounded interval; a *session controller* and a *command-lifecycle controller* bound authority beyond expiry; and a *risk controller* selects deny, scope narrowing, or bounded emergency renewal. We use the Entity Attestation Token [11] under the RATS Attester/Verifier/Relying-Party model [12], and define a concrete EAT profile rather than treating EAT as a complete attestation protocol.

4.2. Fresh-key binding

Attesting a device is not sufficient: a healthy device can pass attestation while an attacker retains a previously copied operational key. CONTAINERD therefore requires that every credential epoch use a newly generated operational key, generated in a TPM, TEE, or secure element where available and marked non-exportable, whose public-key digest is carried in the attestation evidence. The issuer signs only the attested public key, refuses renewal that presents only a prior certificate, rejects replayed evidence and reused nonces, and rotates the key even when the device stays healthy. This is what contains a copied key across the next epoch.

4.3. Value-constrained authorization, and where it is enforced

The physical result of Section 8 is a statement about the *set* of reactive operating points an authorization admits, so the design is only actionable if that set can be expressed and enforced. **FunctionSetAssignments** scopes which *functions* an identity may invoke. No accessible source establishes that IEEE 2030.5 or CSIP can attach a bound on the *value* a control may take, such as “reactive output must remain at or below $-\varphi$ kvar” (row S7, Table 1).

We therefore make the weaker and checkable claim. CONTAINERD’s numeric authorization is a **layer above FunctionSetAssignments, enforced by the DERMS or the gateway proxy**, not a native protocol capability. The

enforcement point holds the bound, rejects or clamps an out-of-set command before forwarding it, and emits only conformant IEEE 2030.5 downstream, so protocol compatibility is preserved and the constraint is applied where the credential is terminated. Whether a future profile could carry the bound natively is a question for the working group, and we do not assume the answer.

4.4. Session and command-effect enforcement

Certificate expiry does not end an open TLS session or an already-issued long-duration control. CONTAINER closes sessions at credential expiry (or bounds session age to the credential TTL) and revalidates authorization per command, and it bounds adversary-issued controls through a maximum command duration, cancellation on containment, and safe-default restoration, with explicit handling of scheduled DERControls. The two quantities the prototype measures are

$$\Delta_{\text{expiry}} = t_{\text{last adv. command}} - t_{\text{expiry}}, \quad (2)$$

$$\Delta_{\text{effect}} = t_{\text{effect ends}} - t_{\text{expiry}}, \quad (3)$$

each targeted to zero or a small declared bound. These are exactly the T_{sess} and T_{cmd} components of BR_{auth} .

4.5. Safe-mode policy

Failure behavior is explicit rather than fail-open. The risk controller chooses among the states in Table 3; no failure mode grants indefinite authority, and the safety of each degraded state is validated under feeder conditions rather than assumed.

4.6. Migration compatibility

We separate three compatibility levels — *protocol* (2030.5 messages stay conformant), *implementation* (unmodified client or server software can participate), and *deployment* (legacy and upgraded devices coexist) — and claim none of them without a passing interoperability test rather than asserting “backward

Table 3: Safe-mode authorization states.

State	Allowed	Denied
Healthy	normal scoped control	out-of-scope control
Verification delayed	read telemetry, hold last safe schedule	new high-impact dispatch
Attestation uncertain	read-only, bounded emergency control	arbitrary set-points
Known compromise	read-only or total denial	all control
Issuer outage	prior low-risk scope, bounded grace	scope expansion, high impact

compatible.” None has yet been tested; Section 8 reports interoperability as untested. Three tiers realize this: a bootstrap-only legacy tier, a gateway-attested proxy tier where an edge gateway holds the operational credential for downstream legacy devices, and a native device-attested tier.

4.7. What non-renewal inherits from the constraints it cites

Section 2 adopts the Sandia analysis’s reasons why online revocation fails for DER: no guaranteed connectivity, no trustworthy time on inverters, and no responsible reporting party. Our mechanism inherits two of the three, and we state that rather than let a reader find it.

Secure time. Expiry is a judgment about time, so an endpoint that cannot trust its clock cannot enforce a short lifetime — the deficiency cited against OCSP — and a skewed device clock would extend a “short-lived” credential indefinitely. So **expiry is never enforced by the endpoint alone**: the issuer refuses renewal server-side where a trustworthy clock exists, each renewal binds a fresh key to a verifier-supplied nonce so a replayed attestation cannot extend authority however the clock reads, and session and command limits are monotonic counters rather than wall-clock deadlines. A skewed clock then costs availability, not containment. We have not measured skew.

Connectivity. A twelve-hour lifetime means a DER losing backhaul for twelve

hours loses control authority, and rural outages of that length are routine. An aggregator that drops a fifth of fleet controllability during a verifier outage has created a reliability hazard while closing a security one. Safe-mode degradation to an autonomous volt-var profile exists for this reason; whether the trade is acceptable is an operator’s call. Our availability figures come from in-process injection, not networked outages, and renewal storms are untested.

Who reports compromise. Attestation detects only what it measures. Firmware integrity is measurable; **a stolen operational key on a device with intact firmware passes attestation**. Per-epoch fresh-key binding answers exactly that class, and it answers it *without* attestation: because renewal mints a fresh key whether or not anything is detected, a copied key is inert after the epoch regardless of the detection probability, and expected retention is $T/2$ under uniform arrival. What attestation bounds is the different class in which the adversary remains resident on the device and re-attests successfully; there retention is $T(1/p - 1/2)$ for uniform arrival, and the familiar T/p only when the compromise lands immediately after an issuance. Table 2 separates them, because reporting one figure for both — as an earlier version of this paper did — credits attestation with a bound key rotation already supplies and, at $T=6\text{ h}$ and $p=0.2$, overstates copied-key retention tenfold. The alternative, a narrow access list on an indefinitely valid credential, contains a copied key only when someone notices and edits the list, which has no bounded latency at all. Bounded beats unbounded; it does not beat instant.

Which tier is deployable. Presenting three tiers evenhandedly would mislead: only one is deployable within the next standards cycle. The native tier needs attestation and a trusted clock on constrained inverter hardware; the legacy tier changes nothing. **The gateway-attested proxy tier resolves all three inheritances at once** — the gateway holds the credential and the clock, attestation runs on capable hardware, downstream devices stay unmodified, and short outages are buffered — and it alone requires no change to already-certified endpoints. We regard it as the deployment path.

4.8. Implementation status

The design is realized as an issuance and renewal service using real X.509 certificates and mutual TLS, with a Python IEEE 2030.5-style client in place of a vendor client, and structured event logging for every credential, session, and command transition. Its security invariants and overhead are reported in Section 8. Two components of the design are specified and enforced in the prototype but not exercised against external hardware or software: the operational credential is not held in a hardware keystore, and no third-party IEEE 2030.5 endpoint has consumed the gateway’s downstream traffic. Section 8.5 states what each absence bounds.

5. Cyber-Side Analysis Engine

We implement the cyber-side impact dimensions as an analysis engine, `pkimodel`, that computes BR_{reach} , BR_{flex} , and BR_{auth} for a compromise locus under a policy. The engine models the identity and delegation graph over the six node types of the threat model, with typed issuance, delegation, and authorization edges. Its central modeling choice follows the formalism: a credential’s reach (which DERs it can address) is represented independently of its scope (which function sets it may invoke at each DER). This is what makes the separating counterexample expressible in code, and we ship that counterexample as a regression test: the two compromises resolve to an identical reachable set of eleven DERs, yet the engine computes zero commandable kW for the attested credential against tens of MW for the legacy one, and a persistence of hours against the analysis horizon.

The authorization policy is parameterized, not fixed: a hardcoded permissive access model would overstate what a stolen certificate can command, so the engine exposes four ACL realism levels spanning single-device, site, feeder-segment, and whole-fleet scope, varied in the evaluation. On a synthetic 200-device fleet over four feeders the reachable-DER count grows from one (single-device and site) to fifty (feeder) to two hundred (fleet), with commandable

capacity in step; the feeder-level figure is the fleet divided by the feeder count and moves with that parameter. This operationalizes RQ1: most reach gained by a compromise is attributable to authorization scope rather than to authentication alone. Retained authority is returned as a distribution over duration, not a point estimate, and separates credential, session, and command-effect components.

The engine consumes synthetic scenarios from a deterministic, seedable generator, since real utility authorization graphs are not public; the generator is released as part of the artifact. The engine is cyber-side only. It produces the reachable-DER set and the commandable-capacity envelope that the feeder simulation consumes to compute BR_{phys} .

6. Feeder Simulation Methodology

Physical consequence is measured by translating an authorized-control set into a dispatch program and running it on public distribution feeders. Every confirmatory result uses one harness, `power/confirmatory.py`, on two feeders: the IEEE 8500-node feeder [13] and the IEEE 123-bus feeder, both built from `PVSystem` objects with an inverter rating and an `InvControl` volt-var controller on the IEEE 1547-2018 Category B default characteristic [14]. The counterfactual throughout is that same fleet at its *legitimate scheduled output* under that characteristic, not a feeder with no DER. The PNNL 9500-node system [15] did not converge in our build, in its base case under its own shipped driver, and contributes no number; Section SM.2 of the supplement names the mode and the build versions so the absence is an explained negative result.

Reference bases, stated because they are easy to get wrong.. An “`InvControl`” declared `RefReactivePower=VARMAX` reads its curve in per unit of `kvarmax`, while a fixed setpoint written to a `PVSystem` is in kvar and clips at that same limit. A bound nominally expressed as “−0.44” therefore means −2.15 kvar through one path and −5.28 kvar through the other, a factor of 2.46: a cross-primitive comparison carried in per-unit is not a comparison of primitives at

all, but of two different absorptions. Every reactive quantity in this work is consequently carried in *physical kvar per DER* and converted at a single site.

The same care applies to the counterfactual. The conformant Category B characteristic absorbs 44% of *nameplate* at $V_4 = 1.08$ p.u., which against a VARMAX reference of that quantity is -1.0 and not -0.44 ; writing the latter yields a legitimate baseline delivering less than half the volt-var support the standard specifies, against which every induced quantity would then be differenced. Penetration is swept through *per-unit rating* rather than fleet count, because IEEE 123 has 91 load buses and a fleet-count sweep returns an identical circuit at every larger fleet. An earlier harness in the released artifact makes the opposite choice on all three points; `artifact/superseded/README.md` records the differences and the numbers they move.

Endpoints.. The primary endpoint is the two-sided ANSI C84.1 Range A violation area, J_{band} , summing overvoltage and undervoltage excursions over all energized nodes. The one-sided overvoltage term is retained as an attack-specific secondary and reported alongside it, never instead: a one-sided endpoint credits an attack for lifting sagging nodes, cannot price the undervoltage that a forced absorption floor causes, and — as §8 shows — scores an attacker that curtails the entire fleet as an *improvement*. Service quality is the shortfall of realised reactive output against what the conformant characteristic prescribes at each unit’s observed terminal voltage, reported as an excess over the paired legitimate arm.

Threshold screen, not a trip.. Every node is screened against the IEEE 1547-2018 Category II overvoltage thresholds (OV2 1.20 p.u./0.16 s; OV1 1.10 p.u./2.0 s), plus a substation reverse-power flag. We call the outcome a *screen* throughout and never a trip, because the model has no persistence timer, no disconnection and no post-disconnection state update: a crossing means a DER at that node would be required to cease to energize, not that a trip was simulated.

Control mode.. We solve with `controlmode=static`, which does *not* disable the feeder’s controls, and release the diagnostic that shows it (`results/controlmode.json`). Reaching the legitimate base case at light load moves 8 of 12 regulators for 32 tap steps and changes 6 capacitor states. Controls are inert only under `controlmode=off`. Regulators and capacitors therefore act against the disturbance in every result reported, and tap operations are reported throughout, including where CONTAINER increases them.

Horizon experiments.. The lifecycle experiments step a moving exogenous state: irradiance on a midday arc with a cloud transient placed deliberately inside the post-expiry window, and load rising toward evening. Within an arm the circuit is stepped forward without recompiling, so taps and capacitor states carry over and post-expiry recovery is a measurement rather than a construction; arms remain independent of one another, each its own compile. Under the predecessor’s static profile, integrated harm was exactly (accrual rate) $\times$ (minutes honoured), so no lifetime comparison could report anything a multiplication would not.

7. Evaluation Methodology

What the pre-registration guarantees, and what it does not.. The hypotheses, endpoints, operating ladder, authorization families, attacker models, interpretation rules and exclusion policy are recorded in `PREREGISTRATION_CONFIRMATORY.md`, **committed to version control before any treatment arm was run**. The ordering is checkable: the commit introducing that document precedes the commit introducing every result file the paper reports. This is a genuine ordering guarantee within the repository and it is what the predecessor version of this work lacked, since there every result predated the repository itself.

It is not an independent timestamp. The commit is authored by the party who could rewrite history, so it establishes ordering to a reader who trusts the repository and not to one who does not. Converting it into an independent

guarantee requires a third-party deposit, which has not been made. We claim repository-internal ordering and nothing more.

Two departures, both disclosed.. Before any result of the shape sweep was seen, the top rung of each penetration ladder and two points of the attacker grid were removed: at those rungs the strong-injection admissible points exhaust the solver’s retry budget and the sweep projected four and a half hours. The first run was stopped and its partial output discarded rather than merged, and both removed rungs sit beyond their feeder’s compliance transition and support no primary claim.

The second departure was made *after* seeing results and is a defect correction. The IEEE 123 fleet had been set to 91, exactly that feeder’s load-bus count, so every seed selected the same buses and merely permuted them: all twenty IEEE 123 seeds were one circuit, returning a single distinct value per rung with degenerate bootstrap intervals. The nominal $n=20$ was an $n=1$. This is the same class of error as the predecessor’s withdrawn ablations — replication reported where the harness produced none — and it is corrected the same way. The IEEE 123 fleet was halved so that placement varies with the seed, those arms were re-run, and the originals were discarded. IEEE 8500, whose 600 units are drawn from 1177 load buses, was unaffected. No hypothesis, endpoint, interpretation rule or seed count changed.

One interpretation rule could not be applied as written, and §8 gives the substitution and the null control that justifies it.

Statistics.. The experimental unit is the complete paired scenario run — (feeder, rung, set, primitive, attacker, seed) — never a node, a timestep or a command. Every contrast is paired on seed: the same seeded fleet placement carries the legitimate baseline and every treatment arm at that seed, and each arm is an independent compile so no solver state leaks between arms. Estimates are the median paired difference with a bias-corrected percentile bootstrap interval at 10,000 resamples; count outcomes additionally carry an exact binomial sign test.

Twenty paired seeds support every primary contrast. Holm correction is applied within each hypothesis family and not across them.

Non-convergence is a recorded outcome, never a dropped run: the retry cap is two with the control-iteration budget tripling $500 \rightarrow 1500 \rightarrow 4500$, unsettled solves are retained and flagged, and every reported aggregate carries its flagged count. The calibration sweep records that IEEE 8500 at 300% penetration does not converge under the corrected characteristic even after the full ladder, which is why the ladder stops below it.

Operating states.. The ladder is calibrated, not assumed. A hosting-capacity sweep under *legitimate* operation only — no treatment, no attacker — locates the penetration at which each feeder’s legitimate volt-var operation stops holding the ANSI upper band, using a tolerance relative to that feeder’s own zero-PV base case, because the IEEE 8500 base is itself marginally out of band with no PV present. The resulting limits are 50% penetration on IEEE 8500 at half load and, on IEEE 123, *right-censored*: that feeder holds the band at every penetration tested up to 1200%, because its voltages stay inside the characteristic’s deadband. That censoring is why the confirmatory ladder is an explicit penetration ladder per feeder rather than fractions of a limit, and why §8 reports fleet reactive absorption alongside penetration — it is the quantity that actually varies with exposure.

8. Results

Results are organised by research question. Every physical estimate is paired by seed, every interval is a bias-corrected percentile bootstrap at 10,000 resamples, and no contrast is reported as a median alone. The primary endpoint throughout is the two-sided ANSI C84.1 Range A violation area $J_{\text{band}} = \sum_n [\max(0, V_n - 1.05) + \max(0, 0.95 - V_n)]$ in per-unit nodes, and ΔJ_{band} is its increment over the paired *legitimate* arm — scheduled PV under the conformant IEEE 1547-2018 Category B volt-var characteristic — at the same seed and operating state.

Two measurement conventions carry the results and are stated here because comparisons of this kind are easy to get wrong. Every reactive bound is expressed in *physical kvar per DER* and converted at one site to whichever per-unit reference each OpenDSS object consumes, so that the two control primitives receive the identical physical quantity. And the legitimate counterfactual delivers the *full* Category B characteristic, absorbing 44% of nameplate at $V_4 = 1.08$ p.u. Section 6 gives both in full.

8.1. RQ1 — *Credential-service correctness and overhead*

The credential service uses real X.509 / ECDSA certificates and an EAT-style attestation token. Ten implemented security invariants pass (Table 4): a bootstrap identity cannot authorize control, issuance requires fresh attestation over a freshly generated operational key, replayed evidence and reused nonces are refused, an expired credential cannot issue a command, scope is checked per command, a bad measurement yields only a narrowed safe-mode scope, a prior epoch cannot self-renew, and a copied prior key fails after rotation. These are the properties the prototype implements and tests; they are not a proof of the design.

On the workstation tier, over 500 iterations, median software-path latencies are 0.03 ms for key generation, 0.06 ms for attestation construction, 0.23 ms for a full attested issuance and 2.3 ms for a real mutual-TLS handshake, and the issuer sustains about 4900 renewals per second single-threaded. **These are software-path timings and no hardware-backed measurement exists.** We attempted one: on an Apple M4 the Secure Enclave refuses key creation to a binary without a code-signing entitlement this build could not obtain, and the platform’s Swift toolchain carries an SDK mismatch that prevents building against the Security framework. The attempt and its failure are recorded in `results/hwkey.json`. Every cryptographic figure in this paper is therefore a software-path figure, and the fresh-key containment claim rests on an *assumption* of non-exportable storage rather than a demonstration of it.

Table 4: Security invariants implemented by the prototype (real X.509/mTLS). All ten pass; the identifiers match `results/credsvc.json`.

ID	Invariant	Result
I1	Bootstrap identity cannot authorize control	pass
I2	Issuance requires a fresh attestation	pass
I3	Credential bound to a fresh public key	pass
I4	Replayed evidence rejected	pass
I5	Expired credential cannot issue a command	pass
I6	Scope enforced per command	pass
I7	Bad measurement yields degraded/denied scope	pass
I8	Prior epoch cannot self-renew	pass
I9	Copied prior key fails after rotation	pass
I10	Active session/command bounded past expiry	pass

8.2. RQ2 — Authorization shape, and the state that decides whether it matters

Setup.. An authorization is a *set*, and an adversary holding a credential scoped to that set plays its worst admissible point. Each set therefore carries a seven-point grid fixed in code before the run, and the reported harm is the maximum over that grid, with the argmax retained. Four families are evaluated: Q1, a symmetric magnitude cap $|q| \leq c$, which contains zero absorption at every width; Q2, an absorption floor $q \in [-Q_b, -\varphi]$, which excludes it; Q3, a tube around the conformant characteristic; and Q5, no remote reactive authority at all. Every set is evaluated under both control primitives at the *identical physical bound*, which is the matched-feasible-set comparison the pilot did not perform. Two feeders, three penetration rungs each, 20 paired seeds, 2520 arms.

Result: consequence tracks the support the feeder is drawing, not penetration..

Table 5 and Fig. 2 are the central conditional result. The harm available from withdrawing reactive support scales with the absorption the fleet was *actually delivering* under the conformant characteristic — from 0.02 p.u.-node at 92 kvar to 415 at 2.6 Mvar — and that quantity is not a function of penetra-

tion. IEEE 123 at 200% penetration draws no absorption at all, because its voltages sit inside the characteristic’s deadband, and there the attack is worth nothing; the same feeder at 800% draws 2.1 Mvar and the attack is worth 36. The two feeders reach comparable harm at penetrations differing by an order of magnitude, and they lie on the same curve once absorption is the abscissa. The operational reading is direct: the quantity that decides an operator’s exposure is one they already meter, and it is fleet reactive absorption rather than installed PV capacity.

Seven rungs per feeder support the curve, of which three per feeder are the confirmatory ladder and four are a post-hoc resolution sweep declared as such (`results/reliance_resolution.json`), plotted with open markers in Fig. 2. The resolution sweep tests no hypothesis; it exists because three points do not establish the shape of a relationship whose endpoints the confirmatory rungs had already fixed.

The effect survives at compliant operating points, on both feeders.. The obvious objection to any result of this kind is that it holds only where the feeder was already broken. It does not. On IEEE 8500 at its calibrated compliant limit, legitimate operation carries a violation area of 0.015 p.u.-node and the worst admissible point of a full-width symmetric cap raises it to 7.5, a factor of 500, though without crossing an IEEE 1547 screen threshold. On IEEE 123 at 400% penetration — also compliant, legitimate area below the calibration tolerance — the same attack raises the area to 5.7 and **crosses the screen in 90% of seeds**. Compliance of the legitimate state is therefore not a defence: a feeder can be inside the band under legitimate volt-var and be driven across a protection threshold by an adversary that injects nothing.

What compliance does predict is magnitude. At the compliant rungs the effect is one to two orders of magnitude smaller than at the overstressed ones, which is the useful part of the conditionality for an operator deciding where to spend attention.

Table 5: Harm tracks the reactive support the feeder draws, not penetration. Worst admissible point of the full-width symmetric cap Q1 under the curve primitive, $n=20$ paired seeds. *Legit.* Q is the fleet reactive output under the conformant characteristic (negative = absorbing); *compliant* is the calibrated criterion of §6. Screen is the fraction of seeds crossing an IEEE 1547 Category II threshold that the paired legitimate case did not cross. [†] This rung is from the post-hoc resolution sweep, not the confirmatory ladder; it is included because it is the compliant state at which the screen fires most often.

Feeder	Pen.	Legit. J_{band}	Compliant	Legit. Q (kvar)	ΔJ_{band}	Screen
IEEE 123	200%	0.000	yes	+42	0.10	0.20
IEEE 123	400% [†]	< 0.10	yes	−459	5.67	0.90
IEEE 123	600%	0.449	no	−1249	17.09	0.80
IEEE 123	1000%	4.219	no	−2189	58.14	0.10
IEEE 8500	50%	0.015	yes	−292	7.50	0.00
IEEE 8500	100%	4.679	no	−872	221.15	1.00
IEEE 8500	150%	24.468	no	−1979	334.50	1.00

Result: shape contains where width does not (H1).. At the exactly matched width of $0.50 Q_b$, a symmetric cap that admits zero absorption is worse than an absorption floor that does not, on every IEEE 8500 rung under both primitives and on every IEEE 123 rung under the curve primitive (Table 6). On IEEE 8500 at 150% the paired difference is 41.1 p.u.-node, CI [38.5, 43.3]. The absorption floor achieves this at essentially no service cost: its excess reactive-support deficit over the paired legitimate arm is +0.07 or less in every supported cell, and the Q5 read-only arm — which grants no remote authority and must by construction cost nothing — reads +0.001, which is the null control that validates the measure.

H1 fails in one place, and we report it rather than aggregate it away: under the *fixed-setpoint* primitive on IEEE 123 the difference is not significant at two rungs and reverses at the third (−2.8, CI [−11.7, −1.9] at 600%). A fixed setpoint applies the same kvar at every node irrespective of local voltage, so on a feeder whose voltage spread is narrow an absorption floor can over-absorb at the low-voltage end and lose more on the undervoltage term than it gains on

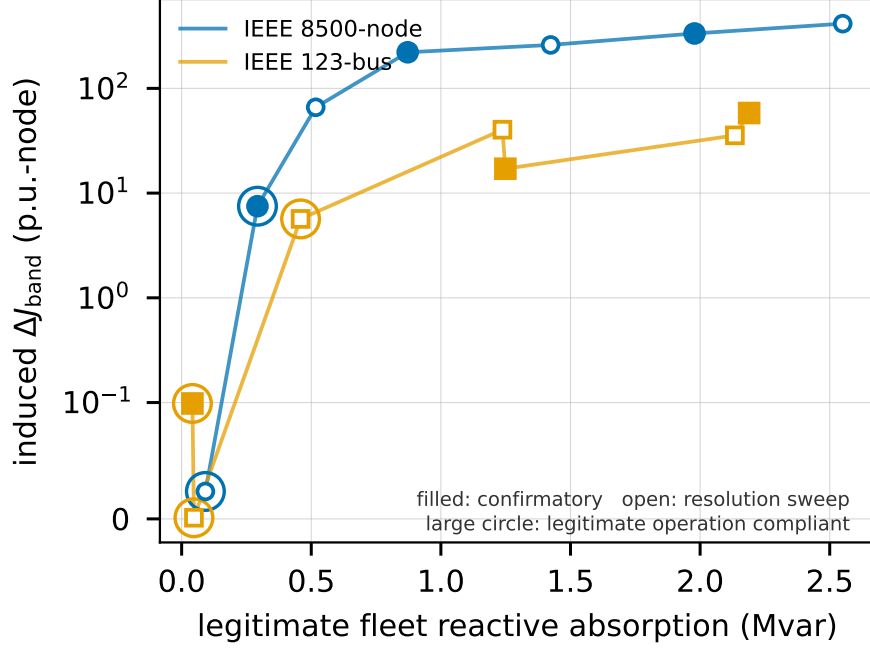


Figure 2: Induced ΔJ_{band} against the reactive absorption the fleet delivers under the conformant characteristic, worst admissible point of the full-width symmetric cap, $n=20$ paired seeds per point, bars are bootstrap 95% intervals. Circled points are rungs at which legitimate operation is compliant. Both feeders lie on the same relationship although their penetrations at comparable harm differ by an order of magnitude, which is why absorption rather than penetration is the quantity an operator should watch.

the overvoltage term. The two-sided endpoint is what makes this visible; the pilot's one-sided endpoint would have scored it as an improvement.

The pre-registered interpretation rule had to be replaced, and this is the disclosure.. The frozen rule required the absorption-floor arm's reactive support deficit to stay below 25% of conformant demand. That threshold presumes the metric reads near zero when nothing is wrong, and it does not: the *legitimate, unattacked* arm scores 0.53 to 0.999 across the ladder, because the reference output is evaluated at a per-unit voltage computed from the bus base while the inverter controller tracks its own rated-voltage reference under damped itera-

Table 6: H1 at exactly matched width ($0.50 Q_b$): symmetric cap Q1 (admits zero absorption) against absorption floor Q2 (excludes it). Paired by seed, $n=20$, bootstrap CI on the paired difference. *Excess deficit* is the Q2 arm’s reactive-support deficit above its own paired legitimate arm.

Feeder	Pen.	Primitive	Q1 – Q2	95% CI	Excess deficit
IEEE 123	200%	curve	0.03	[0.00, 0.06]	–0.000
IEEE 123	600%	curve	3.15	[1.53, 17.53]	+0.002
IEEE 123	1000%	curve	37.08	[26.85, 56.13]	+0.000
IEEE 123	600%	setpoint	–2.81	[–11.73, –1.90]	+0.001
IEEE 8500	50%	curve	1.48	[1.14, 1.83]	+0.146
IEEE 8500	100%	curve	24.24	[22.82, 25.60]	+0.027
IEEE 8500	150%	curve	41.12	[38.48, 43.27]	+0.071
IEEE 8500	150%	setpoint	36.38	[33.31, 43.71]	+0.018

tion. The rule is therefore evaluated on the excess over the paired legitimate arm, with the same 25-point threshold. The substitution is post-hoc; the Q5 null control at +0.001 is the evidence that the differential form measures what the absolute form could not.

Result: the primitive is not neutral ($H3$ rejected).. We pre-registered the expectation that, given matched feasible sets, the two primitives would not differ materially. They do: 43 of 48 matched sets show a paired difference whose CI excludes zero. The direction is not constant — the fixed setpoint is worse where forcing a uniform kvar at every node aggravates the voltage spread, and better where it happens to over-absorb usefully — which is precisely why the effect is a property of *how a bound interacts with the voltage profile* rather than of the function set. The design recommendation is unchanged and does not depend on the primitive: authorize a reactive band that excludes zero absorption. But the pilot’s conclusion that the two primitives “behave the same way” does not survive a matched comparison at 20 seeds, and we withdraw it.

8.3. RQ3, RQ5, RQ6 — What each containment layer is actually worth

Setup.. A sixty-minute horizon with a compromise at minute five, stepped minute by minute through a moving exogenous state: irradiance on a midday arc with a cloud transient placed deliberately inside the post-expiry window, and load rising toward evening. Each arm is one continuous session — taps and capacitor states carry forward — so whether the feeder recovers is a measurement rather than a construction. The pilot’s horizon was static, under which integrated harm is exactly (accrual rate) $\times$ (minutes honoured) and no lifetime comparison can say anything a multiplication could not. Two feeders at their stressed rungs, 20 paired seeds, 22 lifecycle arms each.

Identity denial alone contains nothing — an argument, not a measurement..

We state the epistemic status first, because it is the difference between a result and a tautology. Three arms in Table 7 — credential expiry alone, command cleanup alone, and identity denial — reproduce the long-lived baseline **exactly, in every one of the twenty seeds, to machine precision**. Their paired differences are identically zero, with no variance to put an interval around. That is not a measured null, and we do not report it as one. It follows deterministically from the reach the lifecycle model assigns each response: a denial that refuses new sessions, and does nothing else, cannot touch a session already open or a control already issued, whatever the feeder does downstream.

The substantive question is therefore not whether the simulation confirms it — it cannot — but whether that reach assignment is right. **It is what the accessible standards material leaves open**. Nothing in the Sandia analysis or in CSIP states that adding an identity to a deny list terminates that identity’s established mutual-TLS session, and nothing states that it cancels a scheduled `DERControl`; Section 2 records where each was sought. A denial reaching those layers would be a stronger mechanism than the material specifies, and an implementation is free to build one — which is exactly CONTAINER’s recommendation. We therefore report this as a claim about *unspecified protocol semantics*, and the three arms are marked in Fig. 3 as identical to baseline

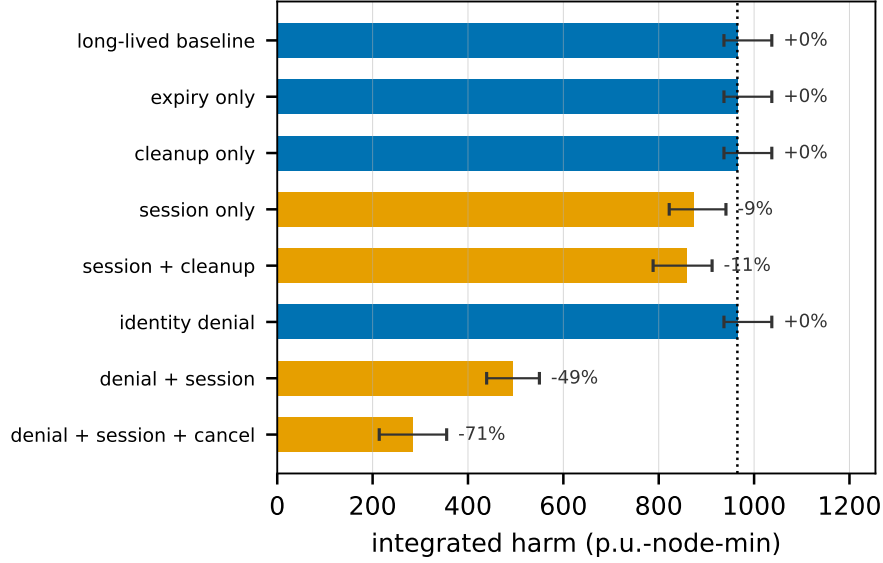


Figure 3: Integrated harm by containment layer, IEEE 8500 at 150% penetration, $n=20$ paired seeds, bars are bootstrap 95% intervals and the dotted line is the long-lived baseline. Dark bars reproduce that baseline *exactly* in every seed — credential expiry alone, command cleanup alone and identity denial each reach neither the open session nor the issued control, so nothing downstream can differ. Those three are not measured nulls and carry no interval; see text. Percentages on the remaining arms are median paired differences.

rather than as measured zeros.

Result: what the layers that do reach are worth.. These contrasts are measurements, and they are what the physical experiment contributes. Against the long-lived baseline, paired by seed, adding session termination to identity denial removes 50.0% of integrated harm on IEEE 8500 (CI [46.5, 54.1], 20/20 seeds) and 47.4% on IEEE 123 (CI [37.2, 70.7], 15/20); adding command cancellation reaches 69.5% (CI [65.8, 77.5]) and 82.3% (CI [63.7, 92.4]). Every contrast survives Holm correction within its family at $\alpha = 0.05$.

Result: neither mechanism suffices alone, for two different reasons (H_4).. The mechanism ablation separates cleanly, which the pilot’s harness could not do — its activity predicate mapped three lifecycles onto one arm, and the resulting

claim was withdrawn. With credential expiry but neither enforcement mechanism (S0), retained authority is $(T_{\text{cred}}, T_{\text{sess}}, T_{\text{cmd}}) = (25, 55, 55)$ minutes and the arm is identical to the long-lived baseline in the sense of the previous paragraph: expiry alone reaches neither layer, so nothing downstream can differ. With command cleanup but no session enforcement (S2) the arm is also identical, but for a reason the model does *not* assume and the simulation does expose — the adversary re-issues over its still-open session after every cleanup sweep, accepting 17 commands where the baseline needed 4. Cleanup fires, and is defeated. Session enforcement alone (S1) bounds the session but leaves a command overhang of one full control duration, $(25, 25, 30)$; only both together (S3) bound the effect at the cleanup latency, $(25, 25, 26)$.

The integral reductions are modest — paired, 11.0% for S1 (CI [9.3, 11.8]) and 15.2% for S3 (CI [11.9, 16.4]) on IEEE 8500, both at 20/20 seeds — because at a 25-minute lifetime the adversary still holds the feeder for 25 of the horizon’s 55 exposed minutes, and the integral is dominated by the pre-expiry period. That is the honest shape of the mechanism: **it truncates the exposure window, it does not attenuate the excursion**, and the size of the benefit is set by the lifetime an operator chooses against the exposure window their detection and response leaves open. The lifetime sweep makes this explicit: integrated harm rises from 283 p.u.-node-min at a five-minute lifetime through 392, 494, 858 and 959 to the 965 of the unbounded baseline at 55 minutes.

How much of this is the mechanism, and how much the parameters? The percentages above are measured at one setting of three quantities the lifecycle model supplies rather than the feeder: the control duration an adversary installs (15 min), the age at which an unenforced session lapses (60 min), and the cleanup sweep latency (60 s). We swept all three — 60 settings in total — and report the range, because a percentage quoted from a single setting invites the reader to mistake a parameter for a property.

Two things separate. **The structural claim is invariant**: identity denial alone reduces the exposure window by 0% in *every one* of the 60 settings. It

Table 7: Retained authority and integrated harm by containment layer, IEEE 8500 at 150% penetration, $n=20$ paired seeds, sixty-minute horizon with compromise at minute five. $(T_{\text{cred}}, T_{\text{sess}}, T_{\text{cmd}})$ in minutes from the compromise. *Change* is the median *paired* difference from the long-lived baseline at the same seed, with a bootstrap 95% interval; *Cmds* is the number of adversarial controls accepted. Arms marked *identical* reproduce the baseline exactly in every seed — a consequence of the reach assigned to that response, not a measured null (see text). p values are Holm-corrected within family; all starred contrasts hold at $\alpha = 0.05$.

Arm	T_{cred}	T_{sess}	T_{cmd}	Cmds	Change vs baseline	Seeds
Long-lived baseline	∞	55	55	4	—	—
S0 expiry only	25	55	55	4	<i>identical</i>	0/20
S2 command cleanup only	25	55	55	17	<i>identical</i>	0/20
S1 session enforcement	25	25	30	2	−11.0% [−11.8, −9.3]*	20/20
S3 both (CONTAINER)	25	25	26	2	−15.2% [−16.4, −11.9]*	20/20
Denylist only, detect +5	5	55	55	4	<i>identical</i>	0/20
+ session termination	5	5	15	1	−50.0% [−54.1, −46.5]*	20/20
+ command cancellation	5	5	6	1	−69.5% [−77.5, −65.8]*	20/20

cannot do otherwise, which is the point of §8’s framing of it as an argument about unspecified semantics rather than a measurement. **The magnitudes are not invariant:** the window reduction from adding session termination ranges from 0 to 90.9% across the grid (72.7% at the nominal setting), and from adding command cancellation from 66.7 to 90.9% (89.1% nominal). An operator running 60-minute controls and a long session cache is in a different regime from one running 5-minute controls, and the ordering of the arms is what survives, not the numbers.

This also shows why the feeder experiment is not redundant with the model. At the nominal setting the exposure window falls 45.5% under session enforcement while the integrated *harm* falls 11.0%: harm does not accrue uniformly over the window, because irradiance and load move, and the pre-expiry period dominates the integral. The mapping from retained authority to physical consequence is not the identity, and reporting the window reduction as though it

were would overstate every result in this subsection by a factor of three to four.

Operational cost.. Bounded lifetime is not free. Regulator tap operations rise from a median of 49 under the unbounded baseline to 56 under S3, and the transition at expiry is what causes them: the cost is incurred by the containment event, not by the attack. An operator choosing a short lifetime is buying truncated exposure with regulator wear, and the voltage endpoint does not price it.

8.4. RQ4 — When lifetime binds, and when detection does

Setup.. The pilot named this its largest gap: an excursion that puts most of a feeder out of band would be surfaced by AMI reporting within a metering interval, so the operative containment latency is the utility’s detection time, not the credential lifetime. Bounded lifetime binds only when detection does not. Five attackers share one operating state and one authorized set, differing only in what they optimise and what they must stay below. The action space is two-dimensional — the reactive point and the active-power fraction — because a stealth attacker trades one against the other: withdrawing absorption raises voltage and curtailing active power lowers it, so a mixture can hold voltage inside the band while still doing damage. An attack is taken to be *voltage-detectable* within a metering interval if it crosses an IEEE 1547 screen threshold or adds more than ten nodes above 1.05 p.u. over the paired legitimate case; this is a declared proxy for AMI-based detection, not a claim about any utility’s monitoring.

Result: the loud attacker is bounded by detection, and the quiet one is not.. Table 8 gives the crossover. The oracle attacker achieves the largest voltage harm on IEEE 8500 at 150% penetration — $\Delta J_{\text{band}} = 406$ p.u.-node — and is flagged by the voltage detector in every seed, crossing a protection screen in every seed. Against that adversary the credential lifetime is irrelevant: any operator watching voltage sees it within one interval, and the containment latency is their response time.

The stealth-constrained attacker inverts the picture. Constrained to cross no screen and to add no nodes above band, it still accrues $\Delta J_{\text{band}} = 14.1$ p.u.-node while the count of over-band nodes *falls* by 180 relative to legitimate operation. It does this by curtailing a quarter of fleet output and holding reactive support at zero, moving the violation onto the undervoltage side of the band — where a one-sided overvoltage endpoint scores it as an improvement. The wear and curtailment attackers go further: subject to the same constraint both settle on full absorption at zero active power, curtailing 100% **of fleet generation** while *reducing* the voltage violation area by 24.5 p.u.-node, and are flagged by the voltage detector in no seed on either feeder.

The stealth result does not survive a detector that watches generation, and we report that rather than the favourable detector alone.. A voltage-only detector is a weak adversary for a claim of this kind. We therefore applied a second detector to the same stored action space, declared after the confirmatory run and labelled post-hoc: generation telemetry flags any attack whose fleet active output departs from schedule by more than 10% of available power. This is data an aggregator already collects for settlement.

Under it the strongest form of the claim collapses. The wear and curtailment attackers are flagged in **every seed on every feeder**: an adversary that switches off the entire fleet is not stealthy in any operational sense, only invisible to the wrong instrument.

We then asked what is left for an adversary that optimises against *both* detectors, by re-searching the same stored action space under the conjunction. The answer is little. On IEEE 8500 at 150% penetration the best dual-evading point accrues $\Delta J_{\text{band}} = 6.0$ p.u.-node — 1.5% of what the oracle achieves — and it curtails *nothing*, because any curtailment large enough to matter trips the generation detector. At the compliant IEEE 8500 rung and on IEEE 123 the best dual-evading point accrues 0.0; in two of twenty seeds on the stressed feeder, and in most seeds elsewhere, no admissible dual-evading point exists at all.

Table 8: Attacker models at IEEE 8500, 150% penetration, $n=20$ paired seeds. *D1* is the confirmatory voltage detector (screen crossing, or more than ten nodes added above 1.05 p.u.); *D2* is the post-hoc generation detector ($> 10\%$ of available active power withheld). *Evades both* is the fraction of seeds flagged by neither. Negative ΔJ_{band} means the attack left the feeder with *less* voltage violation than legitimate operation while doing economic harm. The final row is not an attacker model but the best point available under the conjunction of both detectors, re-searched over the same stored action space; it exists in 18 of 20 seeds.

Attacker	ΔJ_{band}	Curtail	D1 voltage	D2 generation	Evades both
A1 oracle	405.9	19%	1.00	0.55	0.00
A2 telemetry-limited	306.4	0%	1.00	0.00	0.00
A3 stealth-constrained	14.1	25%	0.00	0.75	0.25
A4 wear	-24.5	100%	0.00	1.00	0.00
A5 curtailment	-24.5	100%	0.00	1.00	0.00
<i>best dual-evading</i>	6.0	0%	0.00	0.00	1.00

The honest statement of the lifetime argument is therefore sharply conditional on instrumentation. Against an operator with voltage telemetry alone, a curtailment compromise does its damage unseen and runs until the credential expires — there, bounded lifetime is the only mechanism that ends it. Against an operator who also reconciles fleet generation against forecast, the undetectable residue is small enough that the lifetime argument largely dissolves. We report the second case as well as the first because reporting only the first would make the design look better than the evidence supports.

What this does not settle.. Both detectors are proxies with declared thresholds, and the crossover moves with them: a tighter generation tolerance would catch A3 as well, and an operator reconciling neither instrument would catch none of these. What the result establishes is the structure of the trade rather than a number. The attacks that voltage telemetry misses are close to exactly the ones generation telemetry catches, so an operator’s exposure to a compromise bounded only by credential lifetime is a function of which instruments they reconcile against forecast, not of the adversary’s ingenuity.

8.5. Threats to validity

We report what this evaluation does not establish.

No hardware. Every cryptographic figure is a software-path timing on a workstation. The Secure Enclave attempt failed for the entitlement reason above, and no TPM was available. The fresh-key containment property assumes non-exportable storage rather than demonstrating it.

No third-party interoperability. The IEEE 2030.5 client is ours. Nothing here demonstrates that an unmodified commercial endpoint behaves as modelled, and the session and command-cleanup semantics we enforce are ones the accessible standards material does not specify — which is why we enforce them, but also why no conformance claim follows.

One solver. OpenDSS only; no GridLAB-D cross-check was run. The two feeders differ in voltage level, topology, regulator structure and stiffness, and the direction of every primary contrast agrees across them, but a second solver would test the model rather than the feeder.

The standard’s current edition is unread. IEEE 2030.5-2023 is paywalled and was not obtained. Table 1 states which claims depend on it.

Detection is modelled, not observed. The stealth analysis assumes an AMI-based detector with a declared node-count threshold. It is a proxy, and the crossover between lifetime-bound and detection-bound containment moves with it.

Two disclosed departures from the pre-registration. The penetration ladder lost its top rung and the attacker grid two points, before any result was seen, because the strong-injection arms exhausted the solver retry budget. And the IEEE 123 fleet was initially set to that feeder’s exact load-bus count, so every seed drew the same buses and the twenty IEEE 123 seeds were one circuit; the arms were re-run at half the fleet after the defect was found in the first results. Both are recorded in the pre-registration with the reasoning above.

9. Related Work

Table 9 compares CONTAINER against the concrete systems and standards that answer parts of the same problem, rather than against categories of work.

Workload identity is the closest existing system. SPIFFE and its SPIRE runtime [16, 17] implement almost exactly the chain we describe: attest node and workload, issue short-lived scope-bound X.509 SVIDs keyed to the attested identity, refuse renewal when attestation fails, rely on expiry rather than revocation. Recent work extends it to IoT fleets [18] and nested tokens [19]. The question is therefore whether CONTAINER is workload identity with a DER label, and two differences are load-bearing. First, SPIFFE has no notion of a *physical effect that outlives the credential*: withdrawing a workload identity stops a process opening new connections, but it does not retract a volt-var curve already written into an inverter. Our T_{sess} and T_{cmd} enforcement exists because actuation persists in a way computation does not, and Section 8 measures how far each layer reaches. Second, scope binds to `FunctionSetAssignments`, whose conformant settings are dictated by IEEE 1547-2018 [14] and CSIP [6] rather than chosen freely.

The Web PKI has already adopted non-renewal. The CA/Browser Forum defined a Short-lived Subscriber Certificate in 2023 and *exempted it from CRL and OCSP status checking* [2] — “non-renewal replaces revocation”, already ratified, with Baseline Requirements v2.2.8 setting the threshold at seven days [20] — and ballot SC-081v3 phases maximum TLS validity from 398 days to 47 by 2029 [21]. This is at once the strongest external validation of the premise and the sharpest limit on our novelty. We claim none for short-lived credentials or for expiry-based containment. The same limit applies inside our own problem domain: the Sandia analysis of the DER standards recommends limited-life certificates and states that manufacturers following the IEEE 2030.5 guidance are “not required to limit the life of a device certificate” [1], which makes a short-lived operational credential *permitted* rather than novel. What we claim

is the mapping onto DER authorization: which scope object to bind, which control point to withhold, and that session and command-effect enforcement are separately necessary because grid actuation persists.

Competing key management for power systems. IEC 62351 is the sharpest comparison: Part 8 gives role-based access control [22] and Part 9 specifies key management *including* enrollment and revocation for power-system equipment [23]. Part 9 is a directly competing answer, and the honest question is why 2030.5/CSIP does not adopt it. Not technical superiority on our side: 62351-9’s revocation machinery assumes the connectivity and the responsible reporting party that the Sandia analysis found absent [1], and CSIP deployments certify against the 2030.5 profile. Where an operator has that connectivity, 62351-9 is a reasonable alternative, and we say so rather than claim the field. IEEE 1547.3-2023 is the cybersecurity guide for interconnected DER [24] and the natural home for these recommendations; NISTIR 7628 [25] and IEC 62443 [26, 27] give the enclosing frameworks; NREL’s DER certification line [28, 29] and gap analysis [30] document the certification landscape.

IEEE 2030.5 and CSIP security. The 2018 and 2023 editions mandate mutual TLS with X.509 device certificates [4, 5], constrained for interconnection by CSIP [6]. The closest prior work is the 2030.5 security tutorial of Passos et al. [3], a survey that proposes no redesign, quantifies no feeder consequence, and formalizes no impact metric; Qi et al. survey the broader DER and smart-inverter surface [31].

DER and smart-inverter attacks. High-wattage IoT botnets can move the grid [32, 33]; inverter attacks destabilize grid and market [34]; distribution voltage control is attackable under high PV [35]; and the SUN:DOWN disclosure catalogs fleet-scale inverter vulnerabilities [36]. We tie the attack surface to the credential lifecycle rather than assuming device compromise. Distribution-grid consequence is quantified by the false-data-injection literature [37, 38, 39], grounded by the 2015 Ukraine incident [40] and quantitative risk formulations [41]; our feeder method is supporting, not novel.

Building blocks. ACME [42] and Let’s Encrypt [43] automate issuance,

SCEP [44] is the incumbent device enrollment, and HTTPS-ecosystem measurement quantifies the lifecycle problem [45]. Secure device identity [10], firmware TPM [46] and hardware DICE [47] root the bootstrap layer; the RATS architecture [12], the Entity Attestation Token [11] and BRSKI [48] carry attestation, on established principles [49]. Web-PKI revocation delivery is gap-ridden [50], scalable revocation remains open [51, 52], and OCSP Must-Staple adoption is weak [53]. Attack-graph metrics [54, 55, 56, 8, 9, 7, 57] inform the notation of Section 3, which we do not claim as a contribution. On the power side, IEEE 1547 [14] defines the DER functions, DERMS perform feeder voltage management [58], role-based access control [59] abstracts the scoping we narrow, and HELICS [60, 61] and GridLAB-D [62] are the co-simulation tooling a cross-solver check would use.

10. Ethics and Responsible Disclosure

This work studies the consequences of credential compromise in order to bound them, and it carries a corresponding responsibility. All experiments use synthetic and lab-generated certificates. We use no real vendor keys or secrets, we test against no production DER fleet or any internet-reachable device, and we build no exploit tooling bound to a specific vendor product. The malicious dispatch programs exist only inside the feeder simulation and are never emitted to hardware.

The physical-consequence results describe what a compromised but protocol-conformant credential can already do under the deployed standard; they do not introduce a new vulnerability so much as measure an existing exposure that the standard’s prohibition on revocation leaves unmitigated. The redesign and its migration path are offered as the constructive counterpart to the measurement: the point of quantifying the blast radius is to shrink it.

Disclosure and release, reconciled.. These two commitments are one timeline, not two. Nothing in this work identifies a vulnerability in a specific vendor product; what it identifies is a property of a published standard, which the

Table 9: Positioning against the concrete systems and standards that answer part of the same problem. *Short-lived* = credential lifetime is the containment mechanism; *Attested* = issuance is gated on fresh evidence about the endpoint; *Numeric scope* = the authorization can bound the *value* a control may take, not only which function may be invoked; *Session expiry* = an established session stops accepting commands when the credential authorizing it expires; *Command cleanup* = an already-issued control is retracted; *Physical eval.* = consequence is evaluated on a power-flow model. y = yes, n = no, p = partial, – = not applicable.

System or standard	DER/2030.5	Short-lived	Attested	Numeric scope	Session expiry	Command cleanup	PH
IEEE 2030.5 / CSIP baseline [4, 6]	y	n [†]	n	n	n	n	
SPIFFE / SPIRE [16, 17]	n	y	y	n	p [‡]	–	
BRSKI [48]	n	p	y	n	n	–	
CA/B Forum short-lived certs [2, 20]	n	y	n	n	n	–	
IEC 62351-8 (RBAC) [22]	p	n	n	p	n	n	
IEC 62351-9 (key mgmt) [23]	p	p	n	n	n	n	
CONTAINERD (this work)	y	y	p [§]	y	y	y	

[†]Device certificates have indefinite lifetime and CRL/OCSP are prohibited for IEEE 2030.5 certificates; local allow/deny listing is permitted but not required [1]. [‡]SVID rotation bounds new connections; SPIFFE defines no retraction of an effect already actuated, because a workload has none. [§]Partial: the attestation path is implemented and tested but software-emulated. No hardware-backed key or attestation-quote measurement is reported (Section 8.5).

standards body and the Sandia analysis [1] already describe in public. There is accordingly no embargoed finding whose disclosure must precede release. The artifact — code, result files, and pre-registration — is deposited and citable at the time of publication, which is the same event as public release. Should the confirmatory sweep identify a concrete weakness in a specific implementation, we will notify that implementer and the relevant standards body first and delay only the affected component of the release; the remainder is not held back.

11. Conclusion

IEEE 2030.5 device certificates do not expire and cannot be revoked, and the mechanism the standard sanctions in their place is a local allow or deny list. The assumption that this suffices is the one this paper tests, and it fails: denying the identity of an adversary who is already connected removes *no* integrated feeder harm on either feeder we evaluate. The denial refuses new sessions and does nothing else, while the established session keeps issuing commands and the installed control keeps acting. Containment of a DER compromise is therefore not a property of withdrawing a credential. It is a property of withdrawing authority at every layer that can carry it.

Two results follow. On *duration*, the containment layers are separately necessary and fail alone for different reasons: credential expiry with no further enforcement reaches neither the open session nor the issued control, command cleanup without session enforcement is defeated because the adversary re-issues over its still-open session, and only both together bound the residual effect at the cleanup latency. Against a long-lived credential, session termination on detection removes about half the integrated harm and command cancellation about three quarters. Bounded lifetime truncates the exposure window rather than attenuating the excursion inside it, so the benefit is a lifetime the operator chooses against the exposure their detection and response leaves open, and it is paid for in regulator operations.

On *shape*, an authorization is a set and an adversary plays its worst admissible point. A reactive bound that admits zero absorption fails to contain where an absorption floor of identical width contains, at negligible cost to volt-var service, because withdrawing the reactive support a feeder relies on requires the adversary to inject nothing. That effect is conditional, and the condition is measurable: it scales with the reactive absorption the fleet is actually delivering, not with PV penetration. A feeder can carry ten times its load in PV and be untouched by this attack if its voltages stay inside the characteristic's deadband, while a feeder at half its load in PV is exposed if they do not.

One caveat belongs in the conclusion rather than the limitations, because it bounds the argument for bounded lifetime itself. An adversary doing its damage in curtailed energy is invisible to voltage telemetry, and against it no voltage-based response will ever fire, so credential expiry is the only bound. But it is not invisible to generation telemetry, which aggregators already collect for settlement, and against that instrument a full-curtailement compromise is flagged immediately. The regime in which lifetime is the binding mechanism is therefore real but narrower than a voltage-only analysis suggests. An adversary optimising against both instruments retains only 1.5% of the oracle’s voltage harm on our stressed feeder and none at all on the compliant one. Bounded lifetime is the binding mechanism where an operator watches voltage and not generation; where they reconcile both, it is largely redundant, and we say so.

The recommendation is correspondingly narrow. Authorize a reactive band that excludes zero absorption where the fleet’s measured absorption shows the feeder depends on it; enforce credential expiry at the session and at the command, because enforcing it at the credential alone accomplishes nothing; and place both at a gateway that terminates the operational credential upstream of unmodified endpoints. What remains open is what we could not measure: hardware-backed key storage, third-party interoperability, a second power-flow solver, and the clause-level content of the standard’s edition in force.

Data availability

The analysis engine, the X.509/mutual-TLS credential service, the OpenDSS feeder experiment scripts, the pre-registration document, and every result file underlying the numbers reported here are provided as a single archive accompanying this submission, and will be deposited under a persistent identifier on acceptance; the archive is cited as reference [63]. Each reported numeral is checked against that archive by `check_numbers.py`, which fails if a numeral in the manuscript body, its abstract, the Highlights or the supplementary material cannot be located in the released result files. The IEEE 8500-node and

IEEE 123-bus test feeders are publicly available from the referenced OpenDSS distributions. The one input we cannot redistribute is the IEEE 2030.5-2023 standard text itself, which is sold by IEEE; Section 2 states precisely which claims depend on it and which edition each was checked against.

Funding

This research received no specific grant from any funding agency in the public, commercial, or not-for-profit sectors.

Declaration of competing interest

The author declares that he has no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

CRedit authorship contribution statement

Huan Bui: Conceptualization, Methodology, Software, Validation, Formal analysis, Investigation, Data curation, Writing – original draft, Writing – review and editing, Visualization.

Declaration of generative AI and AI-assisted technologies in the writing process

During the preparation of this work the author used a large language model to assist with copy editing, LaTeX table formatting, and the drafting of code comments in the released artifact. After using this tool the author reviewed and edited the content as needed and takes full responsibility for the content of the published article. No generative AI tool was used to produce, analyse, or interpret any experimental result, and no text generated by such a tool was incorporated without verification against the underlying data.

References

- [1] J. Obert, P. Cordeiro, J. Johnson, G. Lum, T. Tansy, M. Pala, R. Ih, Recommendations for trust and encryption in DER interoperability standards, Tech. Rep. SAND2019-1490, Sandia National Laboratories, Albuquerque, NM (Feb. 2019). doi:10.2172/1761841.
- [2] CA/Browser Forum, Ballot SC063v4: Make OCSP optional, require CRLs, and incentivize automation, passed; voting period 2023-07-06 to 2023-07-13; introduced the Short-lived Subscriber Certificate into Baseline Requirements v2.0.0 (Jul. 2023).
URL <https://cabforum.org/2023/07/14/ballot-sc063v4-make-ocsp-optional-require-crls-and-incentivize-automation/>
- [3] D. Passos, C. de Sousa, R. C. Gomes, D. F. de Assis, F. G. d. O. Passos, C. Albuquerque, A tutorial and security overview on the IEEE 2030.5-2018 standard, IEEE Communications Surveys & Tutorials 27 (6) (2025) 3615–3640. doi:10.1109/COMST.2025.3532110.
- [4] IEEE, IEEE Standard for Smart Energy Profile Application Protocol, IEEE Standards Association (2018). doi:10.1109/IEEESTD.2018.8608044.
- [5] IEEE, IEEE Standard for Smart Energy Profile Application Protocol, IEEE Standards Association; published Dec. 2024 (2023). doi:10.1109/IEEESTD.2024.10785536.
- [6] SunSpec Alliance, Common Smart Inverter Profile (CSIP): IEEE 2030.5 Implementation Guide for Smart Inverters, version 2.1 Edition, released 15 March 2018; supports CA Rule 21 Phase 2 (Mar. 2018).
- [7] N. Poolsappasit, R. Dewri, I. Ray, Dynamic security risk management using bayesian attack graphs, IEEE Transactions on Dependable and Secure Computing 9 (1) (2012) 61–74. doi:10.1109/TDSC.2011.34.

- [8] L. Wang, T. Islam, T. Long, A. Singhal, S. Jajodia, An attack graph-based probabilistic security metric, in: Data and Applications Security XXII (DB-Sec 2008), Vol. 5094 of Lecture Notes in Computer Science, Springer, 2008, pp. 283–296. doi:10.1007/978-3-540-70567-3_22.
- [9] M. Frigault, L. Wang, Measuring network security using bayesian network-based attack graphs, in: 2008 32nd Annual IEEE International Computer Software and Applications Conference (COMPSAC), IEEE, 2008, pp. 698–703. doi:10.1109/COMPSAC.2008.88.
- [10] IEEE, IEEE Standard for Local and Metropolitan Area Networks—Secure Device Identity (2018). doi:10.1109/IEEESTD.2018.8423794.
- [11] L. Lundblade, G. Mandyam, J. O’Donoghue, C. Wallace, The entity attestation token (EAT), RFC 9711, Internet Engineering Task Force (IETF) (Apr. 2025). doi:10.17487/RFC9711.
- [12] H. Birkholz, D. Thaler, M. Richardson, N. Smith, W. Pan, Remote AT-testation procedures (RATS) architecture, RFC 9334, Internet Engineering Task Force (IETF) (Jan. 2023). doi:10.17487/RFC9334.
- [13] R. F. Arritt, R. C. Dugan, The IEEE 8500-node test feeder, in: IEEE PES T&D 2010, IEEE, 2010, pp. 1–6. doi:10.1109/TDC.2010.5484381.
- [14] IEEE, IEEE Standard for Interconnection and Interoperability of Distributed Energy Resources with Associated Electric Power Systems Interfaces (2018). doi:10.1109/IEEESTD.2018.8332112.
- [15] A. Anderson, S. Vadari, J. Barr, S. Poudel, A. Dubey, T. McDermott, R. Podmore, Introducing the 9500 node distribution test system to support advanced power applications: An operations-focused approach, Tech. Rep. PNNL-33471, Pacific Northwest National Laboratory (PNNL), u.S. DOE Office of Scientific and Technical Information (2022). doi:10.2172/1922914.
- [16] The SPIFFE specification: Secure production identity framework for everyone, <https://github.com/spiffe/spiffe>, specification set: SPIFFE ID

and Verifiable Identity Document, SPIFFE Workload API, SPIFFE Workload Endpoint, X.509-SVID, JWT-SVID; accessed 2026-07-31 (2025).

URL <https://github.com/spiffe/spiffe>

- [17] SPIFFE: Secure production identity framework for everyone, Cloud Native Computing Foundation graduated project, accepted to CNCF 2018-03-29; incubating 2020-06-22; graduated 2022-08-23 (2022).

URL <https://www.cncf.io/projects/spiffe/>

- [18] D. Bakoyiannis, G. Kornaros, O. Tomoutzoglou, M. D. Grammatikakis, M. Coppola, Trusting IoT devices at scale in the computing continuum through SPIFFE/SPIRE certificates, in: Applications in Electronics Pervading Industry, Environment and Society (ApplePies 2024), Lecture Notes in Electrical Engineering, Springer, 2025, pp. 279–285. doi:10.1007/978-3-032-17174-0_40.

- [19] H. Z. Cochak, C. C. Miers, P. H. B. Correia, M. A. Marques, M. A. S. Jr., Lightweight SPIFFE verifiable identity document (LSVID): A nested token approach for enhanced security and flexibility in SPIFFE, in: CloudCom, 2024, pp. 9–16. doi:10.1109/CLOUDCOM62794.2024.00015.

- [20] CA/Browser Forum, Baseline requirements for the issuance and management of publicly-trusted TLS server certificates, short-lived Subscriber Certificate defined in Section 1.6.1; validity periods in Section 6.3.2; 47-day maximum effective 2029-03-15 (2026).

URL <https://cabforum.org/working-groups/server/baseline-requirements/requirements/>

- [21] CA/Browser Forum, Ballot SC081v3: Introduce schedule of reducing validity and data reuse periods, approved; voting period 2025-04-04 to 2025-04-11 (Apr. 2025).

URL <https://cabforum.org/2025/04/11/ballot-sc081v3-introduce-schedule-of-reducing-validity-and-data-reuse-periods/>

- [22] IEC, Power systems management and associated information exchange – data and communications security – part 8: Role-based access control for power system management, Tech. Rep. IEC 62351-8:2020, International Electrotechnical Commission, withdrawn 2026-07-22 and superseded by IEC 62351-8:2026; cited here as the edition in force during this work (Apr. 2020).
URL <https://webstore.iec.ch/en/publication/61822>
- [23] IEC, Power systems management and associated information exchange – data and communications security – part 9: Cyber security key management for power system equipment, Tech. Rep. IEC 62351-9:2023, International Electrotechnical Commission, second edition; cancels and replaces IEC 62351-9:2017 (Jun. 2023).
URL <https://webstore.iec.ch/en/publication/66864>
- [24] IEEE, IEEE guide for cybersecurity of distributed energy resources interconnected with electric power systems, Tech. Rep. IEEE Std 1547.3-2023, Institute of Electrical and Electronics Engineers, iEEE Xplore document 10352402 (Dec. 2023). doi:10.1109/IEEESTD.2023.10352402.
- [25] The Smart Grid Interoperability Panel–Smart Grid Cybersecurity Committee, Guidelines for smart grid cybersecurity, Tech. Rep. NISTIR 7628 Revision 1, National Institute of Standards and Technology, Gaithersburg, MD (Sep. 2014). doi:10.6028/NIST.IR.7628r1.
- [26] IEC, Industrial communication networks – network and system security – part 3-3: System security requirements and security levels, Tech. Rep. IEC 62443-3-3:2013, International Electrotechnical Commission (Aug. 2013).
URL <https://webstore.iec.ch/en/publication/7033>
- [27] IEC, Security for industrial automation and control systems – part 4-2: Technical security requirements for IACS components, Tech. Rep. IEC 62443-4-2:2019, International Electrotechnical Commission (Feb. 2019).
URL <https://webstore.iec.ch/en/publication/34421>

- [28] W. Hupp, D. Saleem, J. T. Peterson, K. Boyce, Cybersecurity certification recommendations for interconnected grid edge devices and inverter based resources, Tech. Rep. NREL/TP-5R00-80581, National Renewable Energy Laboratory, Golden, CO (Nov. 2021). doi:10.2172/1832209.
- [29] D. Saleem, M. Slowinske, Cybersecurity certification standard for distributed energy and inverter based resources, Tech. Rep. NREL/PR-5R00-81827, National Renewable Energy Laboratory, Golden, CO, conference presentation; OSTI 1842981 (Jan. 2022).
URL <https://www.osti.gov/biblio/1842981>
- [30] C. MaGill, D. Saleem, J. Waggoner, J. deCastro, DER cybersecurity standards: Assessment and gap analysis, Tech. Rep. NLR/TP-5T00-93100, National Laboratory of the Rockies, Golden, CO (2026). doi:10.2172/3015061.
- [31] J. Qi, A. Hahn, X. Lu, J. Wang, C.-C. Liu, Cybersecurity for distributed energy resources and smart inverters, *IET Cyber-Physical Systems: Theory & Applications* 1 (1) (2016) 28–39. doi:10.1049/iet-cps.2016.0018.
- [32] S. Soltan, P. Mittal, H. V. Poor, BlackIoT: IoT botnet of high wattage devices can disrupt the power grid, in: 27th USENIX Security Symposium (USENIX Security 18), USENIX Association, 2018, pp. 15–32.
- [33] T. Shekari, A. A. Cárdenas, R. Beyah, MaDIoT 2.0: Modern high-wattage IoT botnet attacks and defenses, in: 31st USENIX Security Symposium (USENIX Security 22), USENIX Association, 2022, pp. 3539–3556.
- [34] X. Hui, S. Karumba, S. C.-K. Chau, M. Ahmed, Destabilizing power grid and energy market by cyberattacks on smart inverters, in: Proceedings of the 16th ACM International Conference on Future and Sustainable Energy Systems (e-Energy '25), ACM, 2025, pp. 136–151. doi:10.1145/3679240.3734613.
- [35] Y. Isozaki, S. Yoshizawa, Y. Fujimoto, H. Ishii, I. Ono, T. Onoda, Y. Hayashi, Detection of cyber attacks against voltage control in distri-

- bution power grids with PVs, *IEEE Transactions on Smart Grid* 7 (4) (2016) 1824–1835. doi:10.1109/TSG.2015.2427380.
- [36] Forescout Vedere Labs, SUN:DOWN: Destabilizing the grid via orchestrated exploitation of solar power systems, Vulnerability research report, Forescout Technologies, industry (non-peer-reviewed) report; 46 vulnerabilities across Sungrow, Growatt and SMA, not all CVE-assigned (Mar. 2025).
URL <https://www.forescout.com/research-labs/sun-down-a-dark-side-to-solar-energy-grids/>
- [37] Y. Liu, P. Ning, M. K. Reiter, False data injection attacks against state estimation in electric power grids, in: *Proceedings of the 16th ACM Conference on Computer and Communications Security (CCS '09)*, ACM, 2009, pp. 21–32. doi:10.1145/1653662.1653666.
- [38] R. Deng, G. Xiao, R. Lu, H. Liang, A. V. Vasilakos, False data injection on state estimation in power systems—attacks, impacts, and defense: A survey, *IEEE Transactions on Industrial Informatics* 13 (2) (2017) 411–423. doi:10.1109/TII.2016.2614396.
- [39] G. Liang, J. Zhao, F. Luo, S. R. Weller, Z. Y. Dong, A review of false data injection attacks against modern power systems, *IEEE Transactions on Smart Grid* 8 (4) (2017) 1630–1638. doi:10.1109/TSG.2015.2495133.
- [40] G. Liang, S. R. Weller, J. Zhao, F. Luo, Z. Y. Dong, The 2015 Ukraine blackout: Implications for false data injection attacks, *IEEE Transactions on Power Systems* 32 (4) (2017) 3317–3318. doi:10.1109/TPWRS.2016.2631891.
- [41] A. Teixeira, K. C. Sou, H. Sandberg, K. H. Johansson, Secure control systems: A quantitative risk management approach, *IEEE Control Systems Magazine* 35 (1) (2015) 24–45. doi:10.1109/MCS.2014.2364709.

- [42] R. Barnes, J. Hoffman-Andrews, D. McCarney, J. Kasten, Automatic certificate management environment (ACME), RFC 8555, Internet Engineering Task Force (IETF) (Mar. 2019). doi:10.17487/RFC8555.
- [43] J. Aas, R. Barnes, B. Case, Z. Durumeric, P. Eckersley, A. Flores-López, J. A. Halderman, J. Hoffman-Andrews, J. Kasten, E. Rescorla, S. Schoen, B. Warren, Let’s encrypt: An automated certificate authority to encrypt the entire web, in: Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS ’19), ACM, 2019, pp. 2473–2487. doi:10.1145/3319535.3363192.
- [44] P. Gutmann, Simple certificate enrolment protocol (SCEP), RFC 8894, Internet Engineering Task Force (IETF) (Sep. 2020). doi:10.17487/RFC8894.
- [45] Z. Durumeric, J. Kasten, M. Bailey, J. A. Halderman, Analysis of the HTTPS certificate ecosystem, in: Proceedings of the 2013 Internet Measurement Conference (IMC ’13), ACM, 2013, pp. 291–304. doi:10.1145/2504730.2504755.
- [46] H. Raj, S. Saroiu, A. Wolman, R. Aigner, J. Cox, P. England, C. Fenger, K. Kinshumann, J. Löser, D. Mattoon, M. Nyström, D. Robinson, R. Spiger, S. Thom, D. Wooten, fTPM: A software-only implementation of a TPM chip, in: 25th USENIX Security Symposium (USENIX Security 16), USENIX Association, 2016, pp. 841–856.
- [47] L. Jäger, R. Petri, DICE harder: A hardware implementation of the device identifier composition engine, in: Proceedings of the 15th International Conference on Availability, Reliability and Security (ARES ’20), ACM, 2020, pp. 1–8. doi:10.1145/3407023.3407028.
- [48] M. Pritikin, M. Richardson, T. Eckert, M. Behringer, K. Watsen, Bootstrapping remote secure key infrastructure (BRSKI), RFC 8995, Internet Engineering Task Force (IETF) (May 2021). doi:10.17487/RFC8995.

- [49] G. Coker, J. Guttman, P. Loscocco, A. Herzog, J. Millen, B. O’Hanlon, J. Ramsdell, A. Segall, J. Sheehy, B. Sniffen, Principles of remote attestation, *International Journal of Information Security* 10 (2) (2011) 63–81. doi:10.1007/s10207-011-0124-7.
- [50] Y. Liu, W. Tome, L. Zhang, D. Choffnes, D. Levin, B. Maggs, A. Mislove, A. Schulman, C. Wilson, An end-to-end measurement of certificate revocation in the web’s PKI, in: *Proceedings of the 2015 Internet Measurement Conference (IMC ’15)*, ACM, 2015, pp. 183–196. doi:10.1145/2815675.2815685.
- [51] J. Larisch, D. Choffnes, D. Levin, B. M. Maggs, A. Mislove, C. Wilson, CRLite: A scalable system for pushing all TLS revocations to all browsers, in: *2017 IEEE Symposium on Security and Privacy (SP)*, IEEE, 2017, pp. 539–556. doi:10.1109/SP.2017.17.
- [52] T. Smith, L. Dickinson, K. Seamons, Let’s revoke: Scalable global certificate revocation, in: *Proceedings 2020 Network and Distributed System Security Symposium (NDSS)*, Internet Society, 2020. doi:10.14722/ndss.2020.24084.
- [53] T. Chung, J. Lok, B. Chandrasekaran, D. Choffnes, D. Levin, B. M. Maggs, A. Mislove, J. Rula, N. Sullivan, C. Wilson, Is the web ready for OCSP must-staple?, in: *Proceedings of the Internet Measurement Conference 2018 (IMC ’18)*, ACM, 2018, pp. 105–118. doi:10.1145/3278532.3278543.
- [54] X. Ou, S. Govindavajhala, A. W. Appel, MulVAL: A logic-based network security analyzer, in: *14th USENIX Security Symposium (USENIX Security 05)*, USENIX Association, 2005.
- [55] P. Ammann, D. Wijesekera, S. Kaushik, Scalable, graph-based network vulnerability analysis, in: *Proceedings of the 9th ACM Conference on Computer and Communications Security (CCS ’02)*, ACM, 2002, pp. 217–224. doi:10.1145/586110.586140.

- [56] S. Jajodia, S. Noel, B. O'Berry, Topological analysis of network attack vulnerability, in: *Managing Cyber Threats: Issues, Approaches, and Challenges*, Vol. 5 of *Massive Computing*, Springer, 2005, pp. 247–266. doi:10.1007/0-387-24230-9_9.
- [57] L. Wang, S. Jajodia, A. Singhal, P. Cheng, S. Noel, k-zero day safety: A network security metric for measuring the risk of unknown vulnerabilities, *IEEE Transactions on Dependable and Secure Computing* 11 (1) (2014) 30–44. doi:10.1109/TDSC.2013.24.
- [58] I. Rahman, N. Selak, E. Paaso, Distributed energy resource management system (DERMS) solution for feeder voltage management for utility integrated DERs, in: *2021 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT)*, IEEE, 2021, pp. 1–5. doi:10.1109/ISGT49243.2021.9372281.
- [59] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, C. E. Youman, Role-based access control models, *Computer* 29 (2) (1996) 38–47. doi:10.1109/2.485845.
- [60] T. D. Hardy, B. Palmintier, P. L. Top, D. Krishnamurthy, J. C. Fuller, HELICS: A co-simulation framework for scalable multi-domain modeling and analysis, *IEEE Access* 12 (2024) 24325–24347. doi:10.1109/ACCESS.2024.3363615.
- [61] B. Palmintier, D. Krishnamurthy, P. Top, S. Smith, J. Daily, J. Fuller, Design of the HELICS high-performance transmission-distribution-communication-market co-simulation framework, in: *2017 Workshop on Modeling and Simulation of Cyber-Physical Energy Systems (MSCPES)*, IEEE, 2017, pp. 1–6. doi:10.1109/MSCPES.2017.8064542.
- [62] D. P. Chassin, K. Schneider, C. Gerkensmeyer, GridLAB-D: An open-source power systems modeling and simulation environment, in: *2008 IEEE/PES Transmission and Distribution Conference and Exposition*, IEEE, 2008, pp. 1–5. doi:10.1109/TDC.2008.4517260.

- [63] H. Bui, [dataset] CONTAINER: analysis engine, attested credential service, OpenDSS feeder pipeline, pre-registration, and result files, Zenodo, DOI pending deposit (2026).